

Secure Password Manager — Full Workflow

Course: CMPS426

Group Members:

Yousef Elessawy 1220300
Mohamed Ashraf 4230167
Ahmed Sameh 4230138
Youssef Afify 1220299

1 Overview

The system has 4 modules that chain together:

Module	File	Responsibility
1	<code>elgamal.py</code>	Key generation & storage
2	<code>vault.py</code>	Credential encryption & management
3	<code>signatures.py</code>	ElGamal digital signatures
4	<code>export.py</code>	Secure vault export via Diffie-Hellman

2 Shared Parameters (`config/params.json`)

Both ElGamal and Diffie-Hellman use the same shared domain parameters loaded from `config/params.json`:

Parameter	Value	Source
q (prime)	RFC 3526 — 1536-bit MODP Group 5	RFC 3526, Section 2
α (generator)	31 — verified primitive root of q	Computed locally

3 Step 1 — Setup (Module 1)

CLI option: 1) Initialize new user

1. User enters a username and master password.
2. `elgamal.initialize_user(username)` is called:
 - Loads shared prime q and primitive root α from `config/params.json`.
 - Generates a random private key x in range $(1, q - 1)$.

- Computes public key $y = \alpha^x \bmod q$.
 - Saves both to `keys/` directory as hex files.
3. `vault.create_vault(username, master_pw)` creates an empty encrypted vault in `vaults/`.

4 Step 2 — Store Credentials (Module 2)

CLI option: 2) Add credential

1. User enters username, master password, website, site username, and site password.
2. `vault.add_credential(...)` is called:
 - Loads and decrypts the existing vault (which also verifies the signature first).
 - Appends the new credential entry.
 - Re-encrypts the entire vault with AES-GCM using SHA-256(master_password) as the key.
 - Re-signs the encrypted data and saves back to disk.

5 Step 3 — Sign & Verify (Module 3)

Triggered automatically on every vault read/write.

5.1 Signing (happens on every save)

1. Compute $m = \text{SHA-256}(\text{encrypted_data})$ as an integer.
2. Pick random k where $\text{gcd}(k, q - 1) = 1$.
3. Compute $r = \alpha^k \bmod q$.
4. Compute $k_{\text{inv}} = k^{-1} \bmod (q - 1)$.
5. Compute $s = (m - x \cdot r) \cdot k_{\text{inv}} \bmod (q - 1)$.
6. Store (r, s) in the vault file.

5.2 Verification (happens on every open)

1. Compute $m = \text{SHA-256}(\text{encrypted_data})$.
2. Compute $v_1 = (y^r \cdot r^s) \bmod q$.
3. Compute $v_2 = \alpha^m \bmod q$.
4. If $v_1 = v_2 \Rightarrow$ valid. Otherwise $\Rightarrow$ **vault refuses to open**.

Any manual edit to the vault file (even a single character) causes verification to fail.

6 Step 4 — Retrieve a Credential (Module 2)

CLI option: 3) Get credential

1. Signature is verified first — if tampered, raises an error and stops.
2. Vault is decrypted in memory using $\text{SHA-256}(\text{master_password})$.
3. The matching credential is displayed. Nothing is written back to disk.

7 Step 5 — Export Vault to Another User (Module 4)

CLI option: 7) Export vault to another user

Both users must already be initialized. The export runs 3 phases:

7.1 Phase 1 — Diffie-Hellman Key Exchange

1. Both devices generate ephemeral DH key pairs: private a , public $\alpha^a \bmod q$.
2. Device 1 signs its DH public key with its ElGamal private key $\Rightarrow$ sends to Device 2.
3. Device 2 verifies the signature. If invalid $\Rightarrow$ **aborts**.
4. Device 2 signs its DH public key $\Rightarrow$ sends to Device 1.
5. Device 1 verifies. If invalid $\Rightarrow$ **aborts**.
6. Both compute the shared secret: $S = \text{other_dh_pub}^{\text{my_dh_priv}} \bmod q$.
7. Session AES-256 key = $\text{SHA-256}(S)$.

7.2 Phase 2 — Vault Transfer

1. Device 1 decrypts its vault with the master password.
2. Re-encrypts the plaintext credentials using the session key (AES-GCM).
3. Signs the session-encrypted data with its ElGamal private key.
4. Sends the encrypted package to Device 2.

7.3 Phase 3 — Vault Import

1. Device 2 verifies the transfer signature using Device 1's public key.
2. Decrypts the package using the same session key.
3. Re-encrypts the credentials with Device 2's master password.
4. Signs and saves the new vault under Device 2's username.